

Informe de Evaluación de Vulnerabilidades

27 de julio de 2026

Descripción del sistema

El hardware del servidor consta de un potente procesador CPU y 128GB de memoria. Funciona en la última versión del sistema operativo Linux y aloja un sistema de gestión de bases de datos MySQL. Está configurado con una conexión de red estable usando direcciones IPv4 e interactúa con otros servidores de la red. Las medidas de seguridad incluyen conexiones cifradas SSL/TLS.

Alcance

El alcance de esta evaluación de vulnerabilidades se relaciona con los controles de acceso actuales del sistema. La evaluación cubrirá un periodo de tres meses, desde junio de 20XX hasta agosto de 2020XX. [El NIST SP 800-30 Rev. 1](#) se utiliza para guiar el análisis de riesgos del sistema de información.

Propósito

Considera las siguientes preguntas para ayudarte a escribir:

- ¿Qué valor tiene el servidor de base de datos para el negocio?
 - ¿Por qué es importante para la empresa asegurar los datos en el servidor?
 - ¿Cómo podría afectar el servidor al negocio si estuviera desactivado?
-

Teniendo en consideración las anteriores preguntas, puedo afirmar que:

El propósito de esta evaluación es identificar y mitigar los riesgos derivados de mantener la base de datos MySQL de la empresa expuesta públicamente a Internet durante los últimos tres años. Este servidor es un activo crítico, ya que almacena información estratégica de clientes consultada globalmente por el equipo comercial. Un compromiso o indisponibilidad del sistema comprometería la confidencialidad de los datos, provocaría interrupciones operativas severas y causaría daños reputacionales irreparables. Mediante este informe, se proponen controles que garantizan la continuidad del negocio y la protección de activos sensibles.

Evaluación de riesgos

Fuente de amenaza	Evento de amenaza	Verosimilitud / Probabilidad	Gravedad	Riesgo
Forastero / Hacker (Humano / Externo)	Obtener información sensible mediante exfiltración	3 (Alto)	3 (Alto)	9
Competidor (Humano / Externo)	Realizar ataques de denegación de servicio (DoS)	2 (Moderado)	3 (Alto)	6
Usuario estándar / Empleado (Humano / Interno)	Alterar o eliminar información crítica	2 (Moderado)	2 (Moderado)	4

La fórmula a aplicar en cada fila es: Riesgo = Probabilidad (1-3) x Gravedad (1-3).

Justificación de las puntuaciones:

1. **Hacker (Exfiltración):** Al llevar 3 años expuesta a Internet sin restricción de IP ni perímetro, la probabilidad de un escaneo e intento de exfiltración es 3. La gravedad es 3 porque la fuga de datos de clientes destruye la confianza y además genera sanciones legales.
2. **Competidor (DoS):** Un competidor con recursos moderados puede saturar el servidor MySQL (probabilidad 2). El impacto es alto (gravedad 3) porque perjudica gravemente la operativa de ventas global.
3. **Empleado (Alteración/Eliminación):** Al no haber controles de menor privilegio o roles estrictos, un empleado podría modificar registros accidental o intencionadamente (probabilidad 2, gravedad 2).

Enfoque

Esta sección documenta el enfoque utilizado para realizar el informe de evaluación de vulnerabilidades. Es importante ser claro y conciso al redactar tu enfoque. Un resumen transparente de tu enfoque ayuda a las partes interesadas a entender que la evaluación es creíble y que los resultados pueden utilizarse para tomar decisiones informadas.

Considera las siguientes preguntas para ayudarte a redactar una sección de enfoque:

- ¿Cuál fue tu justificación para seleccionar los riesgos que evaluaste?
 - ¿Cómo estabais derivando las puntuaciones de probabilidad y gravedad de cada riesgo?
 - ¿Cuáles fueron las limitaciones de la evaluación?
-

Teniendo en consideración lo anterior:

Se adoptó un enfoque cualitativo basado en la guía **NIST SP 800-30 Rev. 1** para evaluar los riesgos con mayor impacto operacional y reputacional. Las fuentes y eventos de amenaza seleccionados responden a la exposición pública del servidor durante tres años y al acceso remoto sin controles de red segmentados. Las puntuaciones de probabilidad y gravedad se determinaron analizando la superficie de ataque actual y la criticidad de los datos de comercio electrónico. Las limitaciones principales del estudio radicarón en la falta de registros históricos de auditoría de red detallados.

Estrategia de remediación

Esta sección ofrece recomendaciones específicas y aplicables para remediar o mitigar los riesgos evaluados. Cualquier recomendación que hagas debe ser realista y alcanzable. En general, la sección de remediación de un informe de evaluación de vulnerabilidades ayuda a garantizar que los riesgos se aborden de manera oportuna y eficaz.

Considera las siguientes preguntas para ayudarte a redactar una estrategia de remediación:

- *¿Qué controles técnicos, operativos o de gestión están implementados actualmente para proteger el sistema?*
 - *¿Existen controles de seguridad que puedan reducir los riesgos que evaluasteis? ¿Cuáles son esos controles y cómo remediarían los riesgos?*
 - *¿Cómo mejorarán los resultados de la evaluación la seguridad general del sistema?*
-

Tras considerar las anteriores preguntas, propongo que:

Para mitigar las vulnerabilidades identificadas, se debe restringir inmediatamente el acceso público mediante la implementación de una **VPN** corporativa con autenticación multifactor (**MFA**). Se aplicará el marco **AAA** y el **principio de menor privilegio** para asegurar que cada empleado solo acceda a las tablas de MySQL necesarias. Adicionalmente, se establecerá un **firewall de red** con segmentación explícita y se configurará un sistema de detección de intrusiones (**IDS**) para monitorear exfiltraciones. Estas medidas necesarias elevarán la postura de seguridad sin interrumpir las operaciones remotas.